

Tab 1



Non-Functional Requirement

DZONGJUK

DZONGKHA STANDARD TESTING SYSTEM(DSTS)

*Digital Service Development Division,
Department of Digital Transformation,
GovTech*

Table of Contents

1. Product Requirements	2
1.1. NFR-PROD-001: System Resilience and Performance	2
1.2. NFR-PROD-002: Comprehensive System Security	3
1.3. NFR-PROD-003: Usability and User Experience	4
1.4. NFR-PROD-004: Maintainability and Code Quality	5
1.5. NFR-PROD-005: System Architecture and Portability	6
1.6. NFR-PROD-007: Interoperability	7
2. Organisational Requirements	8
2.1. NFR-ORG-01: Project Management and Quality Assurance	8
2.2. NFR-IRG-002: System Survivability and Data Safety	9
2.3. NFR-ORG-03: Warranty, Support & Maintenance	9
3. External Requirements	10
3.1. NFR-EXT-01: Regulatory Compliance	10
3.2. NFR-EXT-02: Legal and Contractual Requirements	11
3.3. NFR-EXT-04: Third-Party Dependencies	11
3.4. NFR-EXT-05: Open-Source Software Compliance	12
3.5. NFR-EXT-06: Reporting Patent and Copyright	12
3.6. NFR-EXT-07: Service Level Agreements (SLAs) - ATTACH IT WITH WARRANTY and CHECK DSOM	13
3.7. NFR-EXT-08: Future Compatibility	13
Appendix I: Priority, Severity Levels, and Defect Rectification SLA	14
Appendix II: Source Code Management	14
Appendix III: Defect Lifecycle Stages	14
Appendix IV: Defect Rectification SLA	14
Appendix V: Baseline Security Compliance Checklist	15
Annexure I: Disclosure and Accountability Framework	16
Annexure II: Dependency Register	20

Non-Functional Requirements

The following Non-Functional Requirements (NFRs) define the expected quality attributes of the system. These requirements are binding, yet the Consultancy Firms have the opportunity to propose the most suitable means of compliance. Consultancy Firms are encouraged to propose innovative solutions,

provided that they meet or exceed the outcomes described herein. To ensure transparency, all proposals must also include a clear statement of assumptions that underpin the proposed compliance mechanisms.

1. Product Requirements

Intrinsic quality attributes of the system, ensuring its reliability, performance, security, usability, maintainability, and architectural integrity.

1.1. NFR-PROD-001: System Resilience and Performance

The system shall exhibit exceptional resilience and performance, ensuring continuous operation, rapid response times, and efficient resource utilization under varying load conditions. Consultancy Firms are encouraged to outline their approach to resilience (e.g., redundancy, monitoring, scaling strategies) and to explain how performance will be sustained over time.

Aspects: Reliability, Availability, Performance, Scalability.

- 1.1.1. Algorithm and Data Structure Optimization: Select algorithms with the lowest computational complexity and appropriate data structures to reduce processing time. For example, replacing nested loops with hashing can drastically lower execution time. [See also Appendix II - Source Code Management.](#)
- 1.1.2. Asynchronous Processing: Design lightweight components that minimize server round-trips and reduce client-side processing overhead. Asynchronous techniques should be employed to enable non-blocking data retrieval and dynamic page updates without full refreshes. For e.g., offload tasks like sending emails or generating reports to background workers, preventing user-facing delays.
- 1.1.3. Server Round-Trips: Consolidate data retrieval requests into batches to minimize the number of server round-trips and reduce network overhead by adopting frameworks which offer built-in batching capabilities to streamline query execution and improve overall performance.
- 1.1.4. Caching: Implement a multi-level caching strategy (client-side, application-level, database query, CDN) shall be implemented to optimize performance and reduce database load. Define clear cache invalidation policies achieving a cache hit ratio of no less than [90]% for frequently accessed data, with robust and configurable invalidation policies to ensure data freshness.
- 1.1.5. Network Optimization: Minify static assets, compress payloads, and use efficient protocols (HTTP/2, gRPC). For e.g., Combining and compressing static multiple assets to form a light minimal set.
- 1.1.6. Heterogeneous Network connectivity: To ensure resilience in environments with intermittent or unreliable network connectivity, if required, application components should be architected with occasionally-connected capabilities. Solutions are expected to be not only technically sound but also operationally viable.
- 1.1.7. Database: The data layer shall support the target throughput and consistency model with explicit indexing, de/normalization, partitioning/sharding strategy, caching, and connection pooling. Read/write patterns must be profiled and optimized. Active and inactive data shall

be segregated to optimize query performance, archival processes, and resource allocation. The database shall support a minimum of 2,000 transactions per second (TPS) with an average latency of less than 50ms under normal load, and scale linearly with increased resources. It shall be designed for horizontal scalability and ensure data consistency.

- 1.1.8. Performance under Normal Load: The system shall support [500+] concurrent users with an average response time of less than [2] seconds for [95]% of critical transactions (e.g., user login, data retrieval, transaction submission) and less than 3 seconds for all other transactions.
- 1.1.9. Performance under Peak Load: Under peak load conditions (defined as [1,00] concurrent users), the system shall maintain an average response time of less than [3] seconds for [95]% of critical transactions and less than [5] seconds for all other transactions.
- 1.1.10. Scalability: Architect the system so that they can be distributed across multiple nodes to ensure no single point of failure. Break down large monoliths into independent services to allow individual services to scale based on demand. Split large databases into smaller partitions, distributing them across servers for better scalability. Ensure components are loosely coupled to prevent cascading failures and enable independent scaling.

1.2. NFR-PROD-002: Comprehensive System Security

The system shall implement a robust, multi-layered security architecture that safeguards data integrity, confidentiality, and availability. The proposed system shall actively protect against unauthorized access, illicit use, unwarranted disclosure, operational disruption, unauthorized modification, or malicious destruction of data and system resources. Consultancy Firms should describe their layered security model, including approaches to encryption, access management, vulnerability handling, and secure coding practices. Alignment with recognized industry standards (e.g., ISO, OWASP) is encouraged but specific technologies are at the Consultancy Firm's discretion.

Aspects: Data Protection, Access Control, Logging and Auditability, Vulnerability Management, Secure Coding.

- 1.2.1. Data Protection: Protect against inappropriate disclosure of data during transit and storage through a layered approach combining encryption, secure transport protocols, and access controls. See also [Appendix V: Baseline Security Compliance Checklist](#).
- 1.2.2. Access Control: Support both RBAC and ABAC; maintain an auditable access control matrix mapping roles/attributes to permissions; enforce least privilege and MFA for privileged operations. All resources and functions are classified by sensitivity, and access is restricted to users with appropriate roles and clearance levels, ensuring granular control over system interactions. No backdoor access permitted. A comprehensive access control matrix detailing roles, attributes, and corresponding permissions shall be maintained and auditable.
- 1.2.3. Logging and Auditability: All user actions and critical system events shall be comprehensively logged, with logs stored securely and immutably for a minimum of 12 months to facilitate forensic analysis and compliance. Use structured logging (e.g., JSON format) to make logs easily searchable and analyzable. Log detailed error information, including stack traces and request context except for secrets like passwords, tokens, PII, etc.

- 1.2.4. Vulnerability Management: The system shall undergo periodic penetration testing and vulnerability assessments by a party selected by the Procuring Authority. All critical and high-severity vulnerabilities identified shall be remediated within 2 and 4 calendar days, respectively.
- 1.2.5. Secure Coding: The codebase shall be developed using secure coding practices, adhering to industry-standard guidelines (e.g., OWASP Secure Coding Practices, CERT Secure Coding Standards). The code shall be free from known security vulnerabilities as identified by Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST) tools. All critical and high-severity findings from these tools must be remediated prior to production deployment.
- 1.2.6. DevSecOps: A comprehensive DevSecOps approach shall be implemented throughout the entire software development lifecycle, integrating security practices into every phase from design and development to testing, deployment, and operations. This includes automated security testing (SAST, DAST, SCA) integrated into the CI/CD pipeline, infrastructure as code (IaC) with security best practices embedded, continuous monitoring of security posture in production environments, and a clear process for managing and responding to security incidents.
- 1.2.7. The Firm shall demonstrate alignment with industry-recognized best practices for securing all aspects of system operation including data transit, access control, and application-level safeguards as outlined in the [Appendix V: Baseline Security Compliance Checklist](#).

Note: The Firm's solution must be compatible with the Procuring Authority's existing DevSecOps environment, which includes GitLab-based CI/CD pipelines and Docker-based deployment workflows. All tooling, automation, and integration must support and operate within this environment without requiring changes to the Procuring Authority's core infrastructure. Ensure that the components are deployable, testable, and maintainable within the Procuring Authority's DevSecOps ecosystem.

1.3. NFR-PROD-003: Usability and User Experience

The system shall provide an intuitive, efficient, and accessible user experience, minimizing user effort and maximizing productivity. Consultancy Firms are encouraged to describe their user-centered design approach, usability testing methods, and accessibility measures.

Aspects: Transaction Success Rate, Usability Heuristics, System Usability Scale.

- 1.3.1. User Interface and Interaction Design: The application shall be designed with a user-centric approach, ensuring maximum ease of use and reducing cognitive load. Navigation must be intuitive, with consistent visual cues, clear affordances, and minimal friction across tasks.

- 1.3.2. Interactivity and Responsive Design: The application shall leverage advanced interactivity techniques such as AJAX, client-side validation, and dynamic UI updates to enhance responsiveness and reduce page reloads. Real-time feedback mechanisms, inline validation, and progressive disclosure patterns must be used to guide users and improve task completion rates. The UI must remain performant and responsive across devices and network conditions.
- 1.3.3. Asynchronous Background Tasks: Long-running or background operations shall be handled asynchronously so that the UI remains responsive and users are not blocked during processing. Examples include file uploads, report generation, and external service calls. The architecture must support callback mechanisms, polling, or event-driven updates to reflect task completion status in the UI.
- 1.3.4. Control Types and UI Pattern Compliance: All UI components shall be selected based on their appropriateness for the task. Design must ensure consistency, familiarity, and maintainability.
- 1.3.5. Touchpoint Identification and Interaction Mapping: Consultancy Firms shall identify and document all user interaction touchpoints across the application lifecycle, including login, data entry, approvals, notifications, and reporting. Each touchpoint must be mapped to user roles, expected actions, and system responses.
- 1.3.6. User Capability and Context Awareness: The solution shall be designed with an understanding of user capabilities, including their familiarity with digital interfaces, domain expertise, and training levels. UI complexity must be tailored to the expected user base, with optional tooltips, help overlays, and guided tours where necessary.
- 1.3.7. Quality Assurance: Any gaps must be addressed through iterative refinement, ensuring that the final solution meets functional, non-functional, and user experience expectations.
- 1.3.8. Transaction Success Rate: The system shall achieve a first-attempt transaction success rate of no less than 98% for critical user workflows (e.g., user registration, data entry, report generation), as measured during User Acceptance Testing (UAT). However the solution must be in place to record and re-process all the failed transactions.

1.4. NFR-PROD-004: Maintainability and Code Quality

The system shall be highly maintainable, facilitating efficient defect resolution, future enhancements, and long-term sustainability. This necessitates adherence to stringent code quality standards. Consultancy Firms should set out their coding standards, documentation practices, and approaches to testing and code review.

Aspects: Defect Resolution, System Recovery, Coding, Documentation.

- 1.4.1. Defect Resolution: High-priority defects (Severity 1 and Severity 2, see [Appendix I: Priority, Severity Levels, and Defect Rectification SLA](#)) must be resolved with an MTTR specified.
- 1.4.2. System Recovery: The Mean Time To Recover (MTTR) from a complete system failure shall not exceed 2 hours. Also [see Appendix III: Defect Lifecycle Stages](#).
- 1.4.3. Layered Application Design: The application is logically partitioned into distinct tiers, enabling modularity and ease of maintenance through the use of abstract interfaces rather

than concrete classes. Changes in one tier, such as UI updates in the presentation layer or logic updates, do not cascade into other tiers.

- 1.4.4. Code Complexity: The codebase shall maintain a minimal cyclomatic complexity score for no less than [90]% of its modules.
- 1.4.5. Code Complete: The codebase shall be [100]% complete, fully functional, and free from placeholder code, incomplete features, or commented-out sections intended for future development. All modules, functions, and classes shall be fully implemented and integrated. The system shall compile and run without errors or warnings in the specified development and production environments.
- 1.4.6. Coding Standards: The codebase shall rigorously adhere to established coding standards and conventions (e.g., PEP 8 for Python, Google Java Style Guide). For recommended best practices see [Appendix II - Source Code Management](#).
- 1.4.7. Static Analysis: Static code analysis tools (e.g., SonarQube, ESLint) shall be integrated into the development workflow, with all critical and major code smells and bugs remediated prior to merging to main branches.
- 1.4.8. Monitoring, and diagnostics: The application should provide clear, structured data about errors and system changes to help monitor health and fix issues quickly. It must include health check endpoints, performance metrics, and detailed logs that show how the system is behaving. Tracing should be built in to follow requests across services to maintain the system, spot problems early, and keep everything running smoothly over time.
- 1.4.9. Development Model and SDLC Governance: Consultancy Firms shall adopt a collaborative development model supported by tools for workflow, version control, and continuous integration. Architecture, design, and coding standards must be established and enforced through reviews embedded in the SDLC. Also see [Appendix II: Source Code Management](#).
- 1.4.10. Documentation Artifacts: Detailed documentation, including architecture diagrams, interface definitions, class and sequence diagrams, and coding guidelines to provide clarity for developers, Consultancy Firms, and auditors for consistent understanding and traceability. All documentation must be version-controlled and accessible to stakeholders, ensuring traceability and alignment with recommended standards.

1.5. NFR-PROD-005: System Architecture and Portability

The system shall be designed with a modern, modular, and portable architecture, facilitating flexible deployment, future evolution, and vendor independence. Consultancy Firms should describe their architectural approach (e.g., modular services, containerization, use of APIs), how it supports portability, and how it enables adaptability to evolving requirements.

Aspects: Architecture Style, Service Mesh, Deployment Flexibility, Cloud Migration.

- 1.5.1. Architecture Style: The system shall adopt a microservices architecture, characterized by independent, loosely coupled services with well-defined APIs. This architecture shall support containerization (i.e., Docker) and orchestration (i.e., Kubernetes). Any deployment involving Docker or microservices, consultants must not use GovNet private IP address ranges, specifically: 172.16.0.0/12 and 10.0.0.0/8.

- 1.5.2. Service Mesh: A service mesh (e.g., Istio, Linkerd) shall be implemented to manage inter-service communication, providing capabilities such as traffic management, observability, and security.
- 1.5.3. Deployment Flexibility: The system shall be deployable on [Linux, Windows], and a container orchestration platform (e.g., Kubernetes) without requiring any code changes or recompilation. The deployment process shall be fully automated and documented, achieving a deployment success rate of 100% across all specified environments.
- 1.5.4. Cloud Migration: If required, the system shall support migration to different cloud providers (e.g., from AWS to Azure) with minimal effort, demonstrated by a documented migration plan.

1.6. NFR-PROD-007: Interoperability

The system shall seamlessly and securely integrate with designated external systems, facilitating efficient data exchange and process automation. Consultancy Firms should describe their approach to API design, standards supported, and strategies for handling errors and failures.

Aspects: Integration, Communication Patterns, Test, DataHub, NDI.

- 1.6.1. System Integration: The system shall integrate with all identified internal and external systems designated by the Procuring Agency. The Vendor shall, at no additional cost to the Procuring Agency, integrate the system with any new or additional APIs that emerge or are identified during the development phase.
- 1.6.2. Adoption of Domain Best Practices: Consultancy Firms shall leverage established best practice standards relevant to the domain (e.g., HL7 for healthcare, NIEM for government data exchange) rather than introducing proprietary protocols.
- 1.6.3. Semantic Publication of Data: The system must document and publish the semantics of all data it produces or consumes, including definitions, constraints, relationships, and intended usage, to ensure correct interpretation and proper use.
- 1.6.4. Interface Definition and Publication: All interfaces must be clearly defined and published, including supported operations, data types, formats, and protocols.
- 1.6.5. Communication Patterns: All integration points shall support asynchronous communication patterns (e.g., webhooks, message queues) to ensure resilience and scalability.
- 1.6.6. Integration Test Pass Rate: A 100% pass rate shall be achieved for all integration test cases, including performance under load, error handling, and security vulnerability testing.

Note: *A Data Integration within the Procuring Authority will be provided by the Procuring Authority to facilitate integration. Consultancy Firms must ensure their solution can accommodate such inputs without requiring major architectural changes.*

2. Organisational Requirements

Organisational Requirements define the processes, procedures, and operational aspects related to the system's development, deployment, and maintenance, ensuring efficient project execution, quality assurance, and effective support.

2.1. NFR-ORG-01: Project Management and Quality Assurance

The Consultancy Firm shall implement robust project management and quality assurance processes throughout the system's development and deployment lifecycle. Consultancy Firms should set out their methodology, quality management system, and documentation standards. They should also describe training, support, and knowledge transfer mechanisms.

Aspects: Project Management, Quality Management, Documentation, Maintainability, Modularity and Reusability, Traceability, Change Management, Training and Support, DevSecOps.

- 2.1.1. Project Management Methodology: A formal Agile project management methodology shall be adopted and documented, ensuring clear roles, responsibilities, and communication channels. Regular progress reports shall be provided.
- 2.1.2. Quality Management System: A good Quality Management System shall be in place, covering all aspects of software development, testing, and deployment.
- 2.1.3. Documentation: Comprehensive and up-to-date documentation shall be provided, including but not limited to: SRS, system design documents, API documentation, user manuals, administrator guides, and training materials. All documentation shall be clear, concise, and accurate, and updated with every system release.
- 2.1.4. Maintainability Planning: A detailed maintainability plan shall be provided, outlining strategies for long-term system support, including code refactoring, technical debt management, and knowledge transfer.
- 2.1.5. Modularity and Reusability: The system shall be designed with high modularity and reusability, promoting the use of standardized components and interfaces to facilitate future development and reduce redundancy.
- 2.1.6. Traceability: A robust traceability matrix shall be maintained, linking all requirements to design elements, code modules, test cases, and defects, ensuring comprehensive coverage and impact analysis.
- 2.1.7. Change Management: A formal change management process shall be implemented to control and track all changes to requirements, design, code, and documentation, ensuring proper authorization, impact assessment, and communication.
- 2.1.8. Professional Diligence: This obligation is intrinsic to the Firm's role and forms a core rationale for their engagement. See [Annexure I: Disclosure & Accountability Framework](#).
- 2.1.9. Training and Support: Comprehensive training programs shall be provided for different types of users identified by the Procuring Agency, covering system functionality, operation, and troubleshooting. Ongoing technical support shall be provided with defined Service Level Agreements (SLAs) for response and resolution times.

2.2. NFR-IRG-002: System Survivability and Data Safety

The system shall be designed for high survivability, ensuring continuous operation, rapid recovery from major incidents, and robust protection against data loss, corruption, and unauthorized modification.

- 2.2.1. Recovery Time Objective (RTO): RTO of no more than [60] minutes for all services.
- 2.2.2. Data Safety Mechanisms: Robust data safety mechanisms shall be implemented, including comprehensive client-side and server-side input validation, transactional integrity (ACID properties), regular data backups, data encryption at rest and in transit, robust error handling and logging, and mechanisms for data reconciliation and recovery. Data anonymization or pseudonymization shall be used for non-production environments where sensitive data is present.
- 2.2.3. Backup and Data Protection: Consultant shall implement a multi-tiered backup strategy (e.g., full, incremental, application-aware backups, etc). Backup schedules, retention periods, and restoration procedures shall be explicitly proposed and documented. All backups shall be encrypted, stored in separate locations [if required], and tested as demanded by the Procuring Agency to ensure recoverability and integrity.

2.3. NFR-ORG-03: Warranty, Support & Maintenance

- 2.3.1. The Consultancy Firm shall provide a comprehensive warranty for the system, covering all software (and hardware if applicable) components, for a period of at least 12 months from the date of final acceptance.
- 2.3.2. The warranty shall cover defects in materials, workmanship, and functionality, ensuring the system performs according to the agreed-upon specifications and nonfunctional requirements.
- 2.3.3. Any defects identified during the warranty period shall be rectified by the Consultancy Firm at no additional cost to the procuring authority within agreed-upon Service Level Agreement.
- 2.3.4. This warranty period includes:
 - 2.3.4.1. Helpdesk Support: Multi-channel helpdesk support (phone, email, web portal) with guaranteed response and resolution times based on issue severity.
 - 2.3.4.2. Bug Fixing and Patch Management: Proactive identification and resolution of software bugs, and timely application of security patches and updates to all system components.
 - 2.3.4.3. Preventive Maintenance: Regular maintenance activities to ensure optimal system performance, stability, and security, including system health checks, performance tuning, and data integrity checks.
 - 2.3.4.4. Corrective Maintenance: Rapid response and resolution to system failures or incidents, aiming to restore full functionality within agreed-upon RTOs and RPOs.
 - 2.3.4.5. Evolutionary Maintenance: Provision for minor enhancements and adaptations to the system to address evolving business needs or technological changes.
 - 2.3.4.6. Version Upgrades: Provision for [e.g. Major Version] version upgrades(including tech stacks) of the system, including planning, testing, and deployment, to ensure the system remains current and supported as per VAPT report.

Note: The possibility of entering into an Annual Maintenance Contract (AMC) shall be contingent upon the Firm's demonstrated performance during the warranty period.

3. External Requirements

External Requirements define the system's interactions with external entities, including regulatory compliance, third-party dependencies, and service level agreements.

3.1. NFR-EXT-01: Regulatory Compliance

The system shall comply with all applicable laws, regulations, and industry standards relevant to its operation and the data it processes. Consultancy Firms should identify relevant regulations and describe their approach to ensuring compliance.

Aspects: Data Privacy, Industry Standards, Accessibility Standards.

- 3.1.1. Data Privacy: The system shall comply with the Data Protection Act of Bhutan(DPA 2018), General Data Protection Regulation (GDPR) and other relevant data privacy laws (e.g., CCPA), ensuring data minimization, purpose limitation, and data subject rights.
- 3.1.2. Industry Standards: The system shall adhere to relevant industry standards (e.g., PCI DSS for payment processing, HIPAA for healthcare data) as applicable.
- 3.1.3. Accessibility Standards: The system shall comply with Web Content Accessibility Guidelines (WCAG), ensuring accessibility for users with disabilities.
- 3.1.4. Data Sovereignty: All data, including production data, backups, disaster recovery sites, and associated metadata, shall be stored and processed exclusively within data centers located in Bhutan. No data shall be transferred, accessed, or processed outside the geographical boundaries of Bhutan without the explicit written consent of the procuring authority..

3.2. NFR-EXT-02: Legal and Contractual Requirements

The system shall comply with all legal and contractual obligations, including licensing agreements, intellectual property rights, and contractual terms with third-party vendors. Consultancy Firms should describe their approach to managing legal and contractual risks.

Aspects: Licensing, Intellectual Property, Contractual Obligations.

- 3.2.1. Licensing: All third-party software components used in the system shall be properly licensed, with clear documentation of license types (e.g., MIT, Apache) and compliance with their terms.
- 3.2.2. Intellectual Property: The procuring authority shall retain full intellectual property rights over all custom-developed software and configurations. The Consultancy Firm shall indemnify the procuring authority against any claims of intellectual property infringement.
- 3.2.3. Contractual Obligations: The system shall meet all contractual obligations and any associated statements of work.

3.3. NFR-EXT-04: Third-Party Dependencies

The Consultancy Firm shall identify and manage all third-party dependencies, including software libraries, APIs, and external services, ensuring their reliability, security, and compatibility. Consultancy Firms should describe their approach to third-party risk management. All third-party software components shall be regularly updated to their latest stable and secure versions. A Software Bill of Materials (SBOM) shall be provided and maintained.

Aspects: Third-Party Software, External APIs, Cloud Services.

- 3.3.1. Component Name and Version: Precise identification of each third-party component.
- 3.3.2. License Type: The specific license under which each component is distributed (e.g., MIT, Apache 2.0, GPL, commercial).
- 3.3.3. Purpose and Justification: A brief explanation of why each component is necessary and its role in the system.
- 3.3.4. Security Vulnerability Status: Confirmation that each component is free from known critical or high-severity security vulnerabilities, based on a recent scan using industry-standard tools (e.g., OWASP Dependency-Check, Snyk).
- 3.3.5. Support and Maintenance Status: Information on the availability of ongoing support, maintenance, and security updates for each component.
- 3.3.6. External APIs: Reliance beyond identified list of APIs shall be minimized where possible. For necessary APIs, robust error handling, retry mechanisms, and fallback strategies shall be implemented.
- 3.3.7. Cloud Services: If cloud services are utilized, they shall adhere to industry best practices for security, reliability, and data privacy. Cloud service provider certifications (e.g., ISO 27001, SOC 2) shall be provided.

Note: *The Procuring Authority reserves the right to approve or reject the use of any third-party component based on licensing terms, security posture, support availability, or strategic considerations. The Firms shall be responsible for obtaining all necessary licenses and ensuring compliance with their terms.*

3.4. NFR-EXT-05: Open-Source Software Compliance

For all open-source components, the Consultancy Firm shall ensure full compliance with their respective licenses, including any obligations related to attribution, source code disclosure, or derivative works. The Consultancy Firm shall provide a complete list of all open-source licenses and ensure that the system's deployment and operation do not violate any open-source licensing terms.

3.5. NFR-EXT-06: Reporting Patent and Copyright

- 3.5.1. Notification of Infringement: The Consultancy Firm shall promptly notify the procuring authority in writing of any actual or alleged infringement of patents, copyrights, trademarks, or other intellectual property rights related to the system or its components. This notification

shall include all relevant details of the alleged infringement, including the nature of the claim, the parties involved, and any actions taken or proposed by the Consultancy Firm.

- 3.5.2. Indemnification: The Consultancy Firm shall indemnify, defend, and hold harmless the procuring authority from and against any and all claims, liabilities, damages, costs, and expenses (including reasonable attorneys' fees) arising from any actual or alleged infringement of any patent, copyright, trademark, trade secret, or other intellectual property right by the system or its components, provided that such infringement is not caused by the Procuring Authority's unauthorized modification or use of the system. The procuring authority shall provide the Consultancy Firm with prompt notice of any such claim and reasonable assistance in its defense.
- 3.5.3. If a third party alleges that the Solution, or any Product or Component provided under this Contract, infringes a patent or copyright ("IP Claim"), and the Consultancy Firm determines that no reasonable alternative is viable, then upon the Firm's written request and the Procuring Agency's agreement to return the affected item(s), the Consultancy Firm shall propose a compensation package subjected to the Procuring Agency's approval; all communications and decisions related to this process shall be documented and retained for audit purposes.

3.6. NFR-EXT-07: Service Level Agreements (SLAs) - ATTACH IT WITH WARRANTY and CHECK DSOM

Detailed Service Level Agreements (SLAs) will be agreed upon, specifying key performance indicators (KPIs) such as uptime, response times, resolution times, and availability of support personnel/channels. These SLAs will be legally binding and include provisions for penalties in case of non-compliance. [See Appendix IV: Defect Rectification SLA](#)

3.7. NFR-EXT-08: Future Compatibility

The system shall be designed to be compatible with future versions of operating systems, browsers, and other relevant technologies, ensuring long-term usability and reducing the need for costly re-development. Consultancy Firms should describe their strategy for future compatibility.

Aspects: Device Compatibility, Operating System Compatibility, Browser Compatibility, Technology Stack Evolution.

- 3.7.1. System Compatibility: The system shall be compatible with the latest stable versions of major devices, and operating systems for at least two years from the date of deployment. Also, use responsive design principles to ensure the application is accessible and functional on different screen sizes and orientations.
- 3.7.2. Browser Compatibility: The web-based components of the system shall be compatible with the latest two major versions of leading web browsers (e.g., Chrome, Firefox, Edge, Safari).
- 3.7.3. Technology Stack Evolution: The chosen technology stack shall have a clear roadmap for future evolution and be actively supported by its community or vendor.
- 3.7.4. Also see [SOP Compatibility Testing](#).

Appendix I: Priority, Severity Levels, and Defect Rectification SLA

Any defect identified during the warranty period shall be rectified by the Consultancy Firm at no additional cost to the procuring authority, in accordance with the following SLA tiers:

Severity Level	Description	Priority Level	Response Time	Resolution Time
1 (Critical)	System crash, data loss, or security breach	1 (Urgent)	Within 1 hours	As per DSOM standard
2 (High)	Major functionality loss with no workaround	2 (High)	Within 1.5 hours	As per DSOM standard
3 (Medium)	Minor functionality loss or major issue with workaround	3 (Medium)	Within 5 Hour	As per DSOM standard
4 (Low)	Cosmetic or UI-related issue	4 (Low)	Within 12 Hour	As per DSOM standard

Appendix II: Source Code Management

1. [Maintaining Clean Code](#)
2. [Source Code Management](#)

Appendix III: Defect Lifecycle Stages

Status	Description
New	Logged with reproduction steps, expected vs. actual results, and logs/screenshots.
Assigned	Validated by Test Lead, prioritized, and assigned to a developer.
In Progress	The developer is actively working on the fix.
Fixed	Fix has been deployed to the test environment.

In Retest	The original tester verifies the fix against the reported issue.
Closed	The fix has been verified and the defect is resolved.
Reopened	Fix failed verification; defect is reassigned for further investigation.
Rejected/Deferred	Invalid, duplicate, or postponed with justification.

Appendix IV: Defect Rectification SLA

Severity Level	Description	Response Time	Resolution Time
Critical (P1)	System outage or major functionality failure affecting core operations	Within 1 hours	Within 1 hours
High (P2)	Significant degradation or partial failure of key modules	Within 1.5 hours	Within 2 hours
Medium (P3)	Non-critical defect with workaround available	Within 5 hours	Within 6 hours
Low (P4)	Cosmetic or documentation-related issues	Within 12 hours	Within 1 day

Appendix V: Baseline Security Compliance Checklist

NFR ID	Requirement
1	Must implement NDI for all administrative users.
2	Enforce account lockout after 5 failed login attempts.
3	Implement Role-Based Access Control (RBAC).
4	Sessions must auto-expire after 15 minutes of inactivity.
5	Generate new session ID on login and invalidate on logout.
6	Use organization-approved SMTP server with TLS encryption.
7	Do not hardcode SMTP credentials; store them securely in the environment/secrets manager.
8	Log all outbound email events (recipient, status, timestamp).
9	Encrypt sensitive data at rest using AES-256 or equivalent.
10	Encrypt data in transit using latest and stable TLS
11	Store passwords with strong hashing algorithms (bcrypt, Argon2).
12	Mask sensitive data for non-authorized viewers.
13	Validate and sanitize all user inputs to prevent injection attacks.
14	Apply output encoding for displaying user content.
15	Implement secure file upload with file type and size restrictions.
16	Rename uploaded files and store them in restricted directories.
17	Maintain audit logging for key events (login, access, email).
18	Retain logs for a minimum of 90 days.
19	Use separate staging and production environments.
20	Secure APIs with OAuth2 or signed API keys.
21	Apply rate limiting to APIs and use short-lived tokens.
22	Use trusted, up-to-date third-party libraries only.
23	Conduct VAPT before go-live.

24	Follow OWASP Top 10 secure coding practices.
25	Log and alert on suspicious or failed access attempts.

Annexure I: Disclosure and Accountability Framework

1. Purpose

Ensure the successful delivery of software solutions by proactively identifying, disclosing, and managing all critical dependencies early. It mandates that the Consultancy Firms exercise professional diligence in identifying all dependencies that may materially impact the viability, performance, or delivery of the software solution. This framework applies to all engagements where the Consultancy Firm is responsible for the development or delivery of software solutions to the Client, aiming to prevent downstream risks and ensure accountability for project outcomes.

2. Definitions

To ensure consistent interpretation and application of this framework, the following terms are defined:

- 2.1. **Dependency:** Any external factor, component, system, or resource that the successful delivery, performance, or functionality of the software solution relies upon. This includes, but is not limited to, infrastructure (e.g., servers, networks, cloud services), technology stack (e.g., programming languages, frameworks, databases, third-party libraries), integrations (e.g., APIs, data feeds, external systems), and operational elements (e.g., specific processes, client personnel availability, data access).
- 2.2. **Material Impact:** A significant effect on the project's timeline, budget, scope, quality, or the software solution's performance, functionality, or security. An impact is considered material if it could reasonably lead to delays, cost overruns, reduced functionality, or compromised quality that deviates from agreed-upon requirements.
- 2.3. **Professional Diligence:** The standard of care and expertise expected from a competent and experienced solution provider in identifying, analyzing, and managing dependencies within the scope of their engagement. This includes leveraging domain expertise and industry best practices to anticipate and surface dependencies, even if not explicitly stated by the Client.
- 2.4. **Dependency Register:** A formal, dynamic document maintained by the Consultancy Firm to systematically record, track, and manage all identified dependencies throughout the project lifecycle. It serves as a central repository for dependency information, impact analysis, mitigation strategies, and status updates.

2.5. Discovery Phase: The initial stage of a project where the Consultancy Firm gathers information, analyzes requirements, and assesses the existing environment to understand the project's context and identify potential dependencies.

2.6. Mitigation Measure: A planned action or strategy designed to reduce or eliminate the potential negative impact of an identified dependency. This may include design adjustments, alternative technical approaches, or process changes.

3. **Consultancy Firm Duty of Disclosure**

3.1. During the Discovery and Design phases, the Consultancy Firm shall exercise professional diligence in identifying all dependencies, whether explicitly stated by the Client or not to the extent reasonably within the Firm's control and industry knowledge. This includes, but is not limited to, conducting thorough analyses of:

3.1.1. Infrastructure: Existing or required hardware, networking, cloud environments, and related configurations.

3.1.2. Technology Stack: All software components, programming languages, frameworks, libraries, databases, and third-party tools necessary for the solution.

3.1.3. Integration Points: All interfaces, APIs, data sources, and external systems with which the software solution must interact.

3.1.4. Operational Aspects: Any client-side processes, data availability, access permissions, or personnel requirements critical for the solution's development, testing, or deployment.

For the purpose of this obligation, the Consultancy Firm shall be deemed to have knowledge of any such dependencies which, by reason of the Firm's domain expertise and the scope of engagement, ought reasonably to have been identified, anticipated, and surfaced, irrespective of whether such dependencies were expressly specified by the Client. The Consultancy Firm's expertise is a key factor in fulfilling this duty, and reliance solely on Client-provided information without independent verification or analysis is insufficient.

Upon identifying any dependency, the Consultancy Firm shall immediately disclose it to the Client (See [Annexure II: Dependency Register](#)). This disclosure must be comprehensive, detailing the nature of the dependency, its potential material impact on the project (e.g., on timeline, cost, performance, quality), and any associated risks.

4. **Timely Disclosure**

Upon identifying any dependency, the Consultancy Firm shall promptly disclose it to the Client and exercise due care in managing it. This disclosure shall be made within 2 business days of identification and, in all cases, before any potential impact arises.

5. **Proposed Mitigation and Alternatives**

Concurrent with disclosure, the Consultancy Firm shall propose appropriate mitigation measures, design adjustments, or alternative approaches necessary to address the identified dependency and

ensure the successful delivery of the product. These proposals shall be detailed and actionable, outlining the recommended course of action, potential implications of the mitigation, and any required Client support. The Client's review or approval of such proposals shall not relieve the Consultancy Firm of its responsibility to deliver in accordance with the agreed requirements and project objectives, except where delays or failures result directly from (i) the Client's failure to meet its obligations under this Agreement, or (ii) circumstances outside the reasonable control of the Consultancy Firm.

6. Client Support

The Client shall provide reasonable access to infrastructure documentation, stakeholder interviews, and operational walkthroughs to facilitate the Firm's discovery process. However, such support does not absolve the Consultancy Firm from their primary obligation to proactively identify, surface, and manage critical dependencies. The Client's role is supportive, not substitutive of the Consultancy Firm's core duty.

7. Risk Attribution

Firm's failure to identify and disclose such critical dependencies during the discovery or design phases shall constitute a breach of delivery diligence and shall be treated as a deficiency in workmanship. Any resulting delays, cost escalations, or performance failures shall be attributed solely to the Consultancy Firm. Therefore, the following principles of risk attribution and accountability shall apply:

- 7.1. Breach of Delivery Diligence: The Firm's failure to identify and disclose any material dependency during the discovery or design phases, which ought reasonably to have been identified through professional diligence, shall constitute a breach of delivery diligence and shall be treated as a deficiency in workmanship under the terms of the main agreement. Such breaches shall not be subject to any limitation of liability or exclusion of consequential damages under the main agreement.
- 7.2. Sole Attribution of Consequences: Any resulting delays, cost escalations, performance failures, or deviations from agreed-upon requirements that are directly attributable to the Firm's failure to identify and disclose such dependencies shall be attributed solely to the Consultancy Firm. The Consultancy Firm shall bear all associated costs and consequences, including but not limited to, rework, extended timelines, and any penalties or damages as stipulated in the main agreement.
- 7.3. No Waiver of Responsibility: Client review, approval, or provision of support for mitigation proposals does not waive or diminish the Firm's ultimate responsibility for the successful delivery of the software solution and the management of dependencies.

8. Documentation Requirement: The Dependency Register

The Consultancy Firm shall establish and maintain a comprehensive Dependency Register throughout the project lifecycle. This register shall be a living document, regularly updated and made

available to the Client for review. The Dependency Register shall detail, at a minimum, the following information for each identified dependency:

- 8.1. Identified Dependency: A clear and concise description of the dependency.
- 8.2. Nature/Type: Categorization of the dependency (e.g., Infrastructure, Technology Stack, Integration, Operational, Data, Personnel).
- 8.3. Impact Analysis: A detailed assessment of the potential material impact on the project (e.g., timeline, cost, scope, quality, performance, security) if the dependency is not addressed.
- 8.4. Proposed Mitigation or Design Adjustments: The specific actions, strategies, or alternative approaches proposed by the Consultancy Firm to address or mitigate the dependency.
- 8.5. Mitigation Status: The current status of the mitigation efforts (e.g., Proposed, In Review, Approved, In Progress, Completed, Blocked).
- 8.6. Responsible Party for Mitigation: Clearly identify the party (Consultancy Firm or Client) primarily responsible for executing the mitigation measure.
- 8.7. Support Required from Stakeholder(s): Any specific actions, information, or resources required from Client stakeholders to facilitate the mitigation of the dependency.
- 8.8. Date Identified: The date the dependency was first identified and recorded.
- 8.9. Last Updated: The date of the most recent update to the dependency's entry.
- 8.10. Stakeholder Validation Status: Confirmation that the dependency and its proposed mitigation have been reviewed and acknowledged by relevant Client stakeholders.

9. Review and Updates

The Dependency Register shall be reviewed jointly by the Consultancy Firm and Client at regular intervals, typically during weekly project status meetings or at key project milestones. Status of existing dependencies and their mitigation efforts shall be updated.

Annexure II: Dependency Register

Identified Dependency	Nature/Type	Impact Analysis	Proposed Mitigation or Design Adjustments	Mitigation Status	Responsible Party	Support Required from Stakeholder(s)	Date Identified	Last Updated	Stakeholder Validation Status
E.g., Legacy Document Archival System (On-Prem)	Integration / Infrastructure	Proprietary API limits throughput; incompatible auth model; risk of delayed document sync impacting citizen portal responsiveness.	Develop middleware adapter with caching layer; implement phased archival sync; align auth model via service account provisioning.	In Progress.	Consultancy Firm Integration Lead.	Access to archival system documentation; coordination with the IT Ops team.	2025-08-22	2025-08-28	Pending validation from IT Ops and Service Delivery Lead.

*** END of NFR ***